

الاختبار النهائي الشامل: دورة اختبار إختراق تطبيقات الويب (المحاضرات 8-15)

توزيع العلامات: 100 درجة

تعليمات: أجب عن جميع الأسئلة التالية بوضوح ودقة. يُسمح باستخدام الأكواد البرمجية التوضيحية حيثما يلزم.

المحاضرة 8: ثغرات XSS (الجزء الثاني) - التجاوز والسيناريوهات المتقدمة (15 درجة)

- سؤال (2 درجة): ما هو الفرق بين "تصفية المدخلات" (Input Filtering) و "ترميز المخرجات" (Output Encoding)؟
- سؤال (2 درجة): كيف يمكن للمهاجم استغلال وجود بياناته داخل وسم `<script>` حتى لو كانت داخل علامات تنصيص؟
- سؤال (3 درجات): اشرح كيف يمكن استخدام الـ Event Handlers مثل `onerror` و `onfocus` لتجاوز فلاتر الـ WAF التي تمنع وسم `<script>`.
- سؤال (2 درجة): ما هي خطورة استخدام `javascript:` داخل سمة `href` في روابط المواقع؟
- سؤال (2 درجة): كيف يمكن تجاوز حماية المواقع التي تمنع المسافات في الـ Payload الخاص بـ XSS؟
- سؤال (2 درجة): اشرح سيناريو استخدام وسم `<svg>` مع `onload` لتنفيذ XSS.
- سؤال (2 درجة): ما هي تقنية الـ Context-Aware Encoding ولماذا هي مهمة للمطورين؟

المحاضرة 9: ثغرات XSS (الجزء الثالث) - سرقة الجلسة والسيناريوهات العملية (15 درجة)

- سؤال (3 درجات): اشرح بالتفصيل الممل كيف تتم عملية "Session Hijacking" عبر XSS، وما هي المعلومات التي يحتاجها المهاجم؟
- سؤال (2 درجة): كيف يمكن للمهاجم استخدام XSS لتنفيذ "Keylogging" (تسجيل ضربات المفاتيح) على متصفح الضحية؟
- سؤال (2 درجة): ما هي الأداة أو الطريقة التي استخدمها المهندس لاستقبال الكوكيز المسروقة في الشرح العملي؟
- سؤال (2 درجة): اشرح كيف يمكن لثغرة XSS أن تؤدي إلى "Phishing" داخلي في الموقع.
- سؤال (3 درجات): ما هو الفرق بين سرقة الكوكيز العادية وسرقة الكوكيز المحمية بـ `HttpOnly`؟ وهل يمكن لـ XSS الوصول للأخيرة؟
- سؤال (3 درجات): كيف يمكن للمهاجم تغيير محتوى الصفحة (Defacement) برمجياً عبر `document.body.innerHTML`؟

المحاضرة 10: ثغرات SQL Injection (الجزء الأول) - الاكتشاف والأساسيات (10 درجات)

1. سؤال (2 درجة): ما هي الفلسفة وراء استخدام علامة \" \ " لاختبار الثغرة؟ وماذا يعني ظهور " Internal Server Error 500 "؟
2. سؤال (2 درجة): اشرح الفرق بين تعليق الكود في MySQL (#) و PostgreSQL (--).
3. سؤال (2 درجة): لماذا نستخدم ORDER BY بدلاً من GROUP BY لتحديد عدد الأعمدة؟
4. سؤال (2 درجة): كيف يمكن للمهاجم معرفة نوع قاعدة البيانات (MySQL, Oracle, MS SQL) من خلال رسائل الخطأ؟
5. سؤال (2 درجة): ما هو دور الـ Repeater في Burp Suite أثناء تجربة الـ SQLi؟

المحاضرة 11: SQL Injection (الجزء الثاني) - هجمات UNION (15 درجة)

1. سؤال (3 درجات): ما هي الخطوات الثلاث الأساسية لتنفيذ هجوم UNION-based SQLi بنجاح؟
2. سؤال (2 درجة): كيف نحدد أي الأعمدة تقبل البيانات النصية (String) باستخدام UNION SELECT؟
3. سؤال (3 درجات): اشرح كيفية استخراج "أسماء الجداول" من information_schema.tables في MySQL.
4. سؤال (2 درجة): ما هو الجدول الوهمي DUAL في Oracle ولماذا هو ضروري في هجمات الـ UNION؟
5. سؤال (2 درجة): كيف يتم دمج قيم عدة أعمدة في عمود واحد باستخدام CONCAT في MySQL؟
6. سؤال (3 درجات): اشرح الـ Payload المستخدم للحصول على اسم قاعدة البيانات الحالية واسم المستخدم.

المحاضرة 12: SQL Injection (الجزء الثالث) - Blind & Error Based (15 درجة)

1. سؤال (2 درجة): متى نلجأ لاستخدام الـ Blind SQL Injection؟ وما هي "الإشارات" التي نبحث عنها في استجابة السيرفر؟
2. سؤال (3 درجات): اشرح آلية عمل دالة SUBSTRING ودالة LENGTH في استخراج كلمة المرور حرفاً بحرف.
3. سؤال (2 درجة): لماذا يفضل المهندس استخدام "الأتمتة" (Python Scripting) في الـ Blind SQLi؟
4. سؤال (3 درجات): اشرح فكرة الـ Time-based Blind SQLi وكيف نستخدم دالة pg_sleep أو SLEEP().
5. سؤال (3 درجات): كيف نستخدم دالة CAST أو TO_NUMBER لإجبار قاعدة البيانات على إظهار البيانات في رسالة الخطأ؟
6. سؤال (2 درجة): ما هي خطورة الـ Visible Error-based SQLi مقارنة بالـ Blind؟

المحاضرة 13: ثغرات (CSRF (Cross-Site Request Forgery) (10 درجات)

1. سؤال (2 درجة): اشرح مفهوم "الثقة المتبادلة" بين المتصفح والسيرفر وكيف تستغلها CSRF.
2. سؤال (2 درجة): ما هي المكونات الأساسية لـ CSRF Exploit HTML ؟
3. سؤال (2 درجة): كيف يمكن تجاوز حماية CSRF إذا كان السيرفر يتحقق من الـ Referer Header فقط ؟
4. سؤال (2 درجة): ما هي تقنية الـ Anti-CSRF Token وكيف يتم ربطها بجلسة المستخدم ؟
5. سؤال (1 درجة): اشرح كيف يمكن لثغرة XSS أن تساعد في تجاوز أقوى حمايات CSRF.
6. سؤال (1 درجة): ما هي خاصية SameSite في الكوكيز وكيف تمنع هجمات CSRF ؟

المحاضرة 14: ثغرات (XXE (XML External Entity) (10 درجات)

1. سؤال (2 درجة): ما هو الـ DTD (Document Type Definition) وكيف يتم استغلاله لتعريف كيانات خبيثة ؟
2. سؤال (2 درجة): اشرح الـ Payload المستخدم لقراءة ملف etc/passwd/ عبر XXE.
3. سؤال (2 درجة): كيف يمكن تنفيذ هجوم "Denial of Service" (تعطيل الخدمة) باستخدام XXE (هجوم Billion Laughs) ؟
4. سؤال (2 درجة): ما هو الـ Out-of-band XXE (OAST) ومتى نستخدمه ؟
5. سؤال (2 درجة): كيف نستخدم بروتوكول php://filter لقراءة ملفات الـ PHP دون تنفيذها عبر XXE ؟

المحاضرة 15: ثغرات (IDOR (Insecure Direct Object Reference) (10 درجات)

1. سؤال (2 درجة): اشرح سيناريو تغيير الـ user_id في رابط الملف الشخصي للوصول لبيانات الآخرين.
2. سؤال (2 درجة): كيف يمكن استغلال IDOR في "تغيير كلمة المرور" لمستخدم آخر ؟
3. سؤال (2 درجة): ما هي الطريقة الصحيحة (برمجياً) لمنع IDOR ؟ (Access Control Checks).
4. سؤال (2 درجة): هل استخدام الـ UUID بدلاً من الأرقام التسلسلية يحل مشكلة IDOR نهائياً ؟ ولماذا ؟
5. سؤال (2 درجة): اشرح كيف يمكن اكتشاف IDOR في الـ API Endpoints التي تستخدم طلبات PUT أو DELETE .

بالتوفيق في الاختبار!